

CMMC LEVEL 1

Self-Assessment Report

Organization Name:	[Enter Organization Legal Name]
CAGE Code:	[Enter CAGE Code]
Primary Contract #:	[Enter Contract Number]
Contracting Agency:	[Enter Agency / DoD Component]
Assessment Date:	[MM/DD/YYYY]
Assessor Name / Title:	[Name, Title]
SPRS Submission Date:	[MM/DD/YYYY]
Report Version:	1.0

CONFIDENTIAL — FOR INTERNAL USE AND CONTRACT COMPLIANCE ONLY

Table of Contents

1. Executive Summary
2. Scope
3. Assessment Methodology
4. System Inventory
5. Assessment Results by Domain
6. Scoring Summary
7. Plan of Action & Milestones (POA&M)
8. Attestation & Signatures

1. Executive Summary

This document presents the results of a CMMC Level 1 self-assessment conducted by [Organization Name] in accordance with the Cybersecurity Maturity Model Certification (CMMC) framework, Version 2.0, and the requirements set forth in 48 CFR 52.204-21 (Basic Safeguarding of Covered Contractor Information Systems).

CMMC Level 1 encompasses 17 cybersecurity practices across 6 domains. These practices are derived from the Federal Acquisition Regulation (FAR) and are intended to protect Federal Contract Information (FCI) processed, stored, or transmitted on the organization's information systems.

Assessment Outcome: [Met / Not Met / Partially Met — summarize overall posture here. Note total score if calculated.]

Any practices not fully implemented are captured in the Plan of Action & Milestones (POA&M) in Section 7. This self-assessment will be submitted to the Supplier Performance Risk System (SPRS) as required.

2. Scope

2.1 Assessment Boundary

[Describe which systems, networks, facilities, and personnel are included in scope. Include any cloud services, third-party services, or external systems that process FCI.]

2.2 Federal Contract Information (FCI) Definition

Federal Contract Information (FCI) means information, not intended for public release, that is provided by or generated for the Government under a contract to develop or deliver a product or service to the Government, but not including information provided by the Government to the public (e.g., on public websites) or simple transactional information.

2.3 Exclusions

[List any systems, locations, or populations explicitly excluded from scope and the rationale.]

3. Assessment Methodology

This self-assessment was conducted by the organization's designated security representative(s) using the following methods:

Method	Description
Documentation Review	Review of policies, procedures, system configurations, and prior assessments.
Interviews	Interviews with system owners, administrators, and relevant personnel.
Observation	Direct observation of system controls, physical security, and operational practices.
Testing	[Describe any technical testing performed, e.g., vulnerability scans, configuration review.]

Status definitions used in this report:

Status	Definition
MET	The practice is fully implemented and verifiable evidence exists.
PARTIAL	The practice is partially implemented; gaps exist and are documented in the POA&M.
NOT MET	The practice is not implemented. A remediation plan is required in the POA&M.

4. System Inventory

The following systems and assets are included in scope for this assessment:

Asset ID	System / Asset Name	Type	Owner	FCI Present?
SYS-001				Yes / No
SYS-002				Yes / No
SYS-003				Yes / No
SYS-004				Yes / No

[Add rows as needed. Types include: Server, Workstation, Laptop, Network Device, Cloud Service, Mobile Device, Storage Device, etc.]

5. Assessment Results by Domain

The following tables document the assessment findings for each of the 17 CMMC Level 1 practices. Complete each table with implementation descriptions, supporting evidence, and status.

Domain: Access Control

AC.L1-3.1.1 NIST SP 800-171 r2 Ref: 3.1.1	Requirement: Limit information system access to authorized users, processes acting on behalf of authorized users, and devices (including other information systems).		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

AC.L1-3.1.2 NIST SP 800-171 r2 Ref: 3.1.2	Requirement: Limit information system access to the types of transactions and functions that authorized users are permitted to execute.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

AC.L1-3.1.20 NIST SP 800-171 r2 Ref: 3.1.20	Requirement: Verify and control/limit connections to external information systems.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

AC.L1-3.1.22 NIST SP 800-171 r2 Ref: 3.1.22	Requirement: Control CUI posted or processed on publicly accessible information systems.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

Domain: Identification & Authentication

IA.L1-3.5.1 NIST SP 800-171 r2 Ref: 3.5.1	Requirement: Identify information system users, processes acting on behalf of users, and devices.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

IA.L1-3.5.2 NIST SP 800-171 r2 Ref: 3.5.2	Requirement: Authenticate (or verify) the identities of those users, processes, or devices, as a prerequisite to allowing access to organizational information systems.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

Domain: Media Protection

MP.L1-3.8.3 NIST SP 800-171 r2 Ref: 3.8.3	Requirement: Sanitize or destroy information system media containing Federal Contract Information before disposal or reuse.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

Domain: Physical Protection

PE.L1-3.10.1 NIST SP 800-171 r2 Ref: 3.10.1	Requirement: Limit physical access to organizational information systems, equipment, and the respective operating environments to authorized individuals.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

PE.L1-3.10.3 NIST SP 800-171 r2 Ref: 3.10.3	Requirement: Escort visitors and monitor visitor activity.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]	
	Evidence / Artifacts:	[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]	
	Notes / Gaps:	[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]	

PE.L1-3.10.4 NIST SP 800-171 r2	Requirement: Maintain audit logs of physical access.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:		
	Evidence / Artifacts:		
	Notes / Gaps:		

Ref: 3.10.4	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>

PE.L1-3.10.5 NIST SP 800-171 r2 Ref: 3.10.5	Requirement: Control and manage physical access devices.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>	
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>	
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>	

Domain: System & Communications Protection

SC.L1-3.13.1 NIST SP 800-171 r2 Ref: 3.13.1	Requirement: Monitor, control, and protect organizational communications (i.e., information transmitted or received by organizational information systems) at the external boundaries and key internal boundaries of the information systems.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>	
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>	
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>	

SC.L1-3.13.5 NIST SP 800-171 r2 Ref: 3.13.5	Requirement: Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>	

	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>

Domain: System & Information Integrity

SI.L1-3.14.1 NIST SP 800-171 r2 Ref: 3.14.1	Requirement: Identify, report, and correct information and information system flaws in a timely manner.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>	
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>	
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>	

SI.L1-3.14.2 NIST SP 800-171 r2 Ref: 3.14.2	Requirement: Provide protection from malicious code at appropriate locations within organizational information systems.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>	
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>	
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>	

SI.L1-3.14.4 NIST SP 800-171 r2 Ref: 3.14.4	Requirement: Update malicious code protection mechanisms when new releases are available.		Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>	
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>	

	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>
--	----------------------	--

SI.L1-3.14.5 NIST SP 800-171 r2 Ref: 3.14.5	Requirement: Perform periodic scans of the information system and real-time scans of files from external sources as files are downloaded, opened, or executed.	Status ☐ MET ☐ PARTIAL ☐ NOT MET
	Implementation Description:	<i>[Describe how this practice is implemented. Reference specific tools, policies, configurations, or procedures.]</i>
	Evidence / Artifacts:	<i>[List supporting evidence: policy name/version, screenshot filename, configuration export, interview notes, etc.]</i>
	Notes / Gaps:	<i>[Describe any gaps, exceptions, or compensating controls. Reference POA&M item number if applicable.]</i>

6. Scoring Summary

CMMC Level 1 uses the same 110-point scoring model as NIST SP 800-171. Each of the 17 practices carries equal weight. A perfect score is 110. Each NOT MET practice deducts points; each PARTIAL practice deducts a partial value. The score must be submitted to SPRS.

Domain	# Practices	# Met	# Not Met	Notes
Access Control	4			
Identification & Authentication	2			
Media Protection	1			
Physical Protection	4			
System & Communications Protection	2			
System & Information Integrity	4			
TOTAL	17			

Scoring Metric	Value
Calculated SPRS Score	[Enter score, e.g. 110]
SPRS Submission Date	[MM/DD/YYYY]
SPRS Submission User	[Name and CAGE Code]

7. Plan of Action & Milestones (POA&M)

List all practices that received a status of PARTIAL or NOT MET. Each item must include a remediation plan and target completion date. This POA&M must be reviewed and updated at least annually.

POA&M #	Practice ID	Gap Description	Remediation Plan	Responsible Party	Target Date
P-001					MM/DD/YYYY
P-002					MM/DD/YYYY
P-003					MM/DD/YYYY
P-004					MM/DD/YYYY
P-005					MM/DD/YYYY

[Add or remove rows as needed. Delete this section if all 17 practices are fully met.]

8. Attestation & Signatures

By signing below, the authorized official affirms that the information contained in this CMMC Level 1 Self-Assessment Report is accurate and complete to the best of their knowledge, and that the organization has implemented the practices described herein to protect Federal Contract Information (FCI).

The organization acknowledges that intentional misrepresentation of assessment results submitted to SPRS may constitute a violation of the False Claims Act (31 U.S.C. §§ 3729–3733).

Attestation Field	Details
Authorized Official Name:	
Title:	
Organization:	
Date Signed:	
Signature:	

IT/Security Representative (if separate from authorized official)

Name:	
Title:	
Date:	
Signature:	